INFORME DE HARDENING DE INFRAESTRUCTURA Y CONTENEDORES

Proyecto IMSJ - Portal vial y API REST

RESULTADO	APROBADO
Servicios	Apache/PHP y MySQL saludables
Endurecimiento	Usuarios no privilegiados, no-new-privileges, capacidades mínimas y raíz de solo lectura
Regresión	41 aprobadas, 0 fallidas, 2 omitidas, salida 0
Fecha	21 de octubre de 2026

Documento: IMSJ-CIB-HARD-2026-10-21

Versión evaluada: rama main, HEAD 5f15b3b9313d con cambios de hardening aún pendientes de asociación al commit final.

Responsable documental: equipo RC5. Alcance: entorno Docker local autorizado y datos de prueba.

1. Resumen ejecutivo

Se endurecieron los dos servicios Docker del proyecto IMSJ sin alterar su funcionalidad observable. La aplicación se ejecuta íntegramente como www-data; MySQL lo hace como mysql. Ambos contenedores impiden la elevación de privilegios, descartan capacidades Linux y utilizan una raíz de solo lectura. Apache conserva únicamente CAP_NET_BIND_SERVICE para escuchar en el puerto interno 80; MySQL no conserva capacidades adicionales.

Conclusión

Los controles quedaron incorporados al compose.yaml utilizado por iniciar.bat. Los dos healthchecks finalizaron en estado healthy y la auditoría de regresión no registró fallos.

2. Objetivo y alcance

El objetivo fue reducir el impacto de una eventual explotación dentro de los contenedores y comprobar que las restricciones no impiden el arranque, la persistencia, los healthchecks ni los controles de seguridad de la API. Las pruebas se limitaron a la estación local autorizada, en 127.0.0.1:8000, con Docker Desktop y datos de prueba. No se realizó explotación contra sistemas externos.

3. Metodología

Paso	Actividad	Criterio de aceptación
1	Línea de base y healthchecks	app y db saludables; MySQL sin puerto publicado
2	Aplicación gradual de controles	Recrear un servicio por vez y conservar disponibilidad
3	Inspección de runtime	Usuario, capacidades, no-new-privileges y ReadonlyRootfs visibles
4	Regresión de API	Cero pruebas fallidas y salida 0
5	Arranque habitual	iniciar.bat conserva los controles

4. Matriz de controles aplicados

Control	Aplicación	MySQL	Resultado
Usuario no privilegiado	www-data	mysql (UID 999)	Cumple
no-new-privileges	Activo	Activo	Cumple
Capacidades Linux	DROP ALL; agrega NET_BIND_SERVICE	DROP ALL; no agrega	Cumple
Raíz de solo lectura	Activa	Activa	Cumple
Directorios temporales	/tmp, /run/apache2, /var/lock/apache2	/tmp, /var/run/mysqld	Cumple
Datos persistentes	uploads y cache en volúmenes	db_data en volumen	Cumple
Exposición de red	127.0.0.1:8000 -> 80	Sin publicación al host	Cumple

Configuración efectiva resumida

```
services:
  app:
    user: www-data
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    cap_add: [NET_BIND_SERVICE]
    tmpfs: [/tmp, /run/apache2, /var/lock/apache2]

  db:
    user: mysql
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    tmpfs: [/tmp, /var/run/mysqld]
```

Evidencia 1

Bloqueo de elevación de privilegios

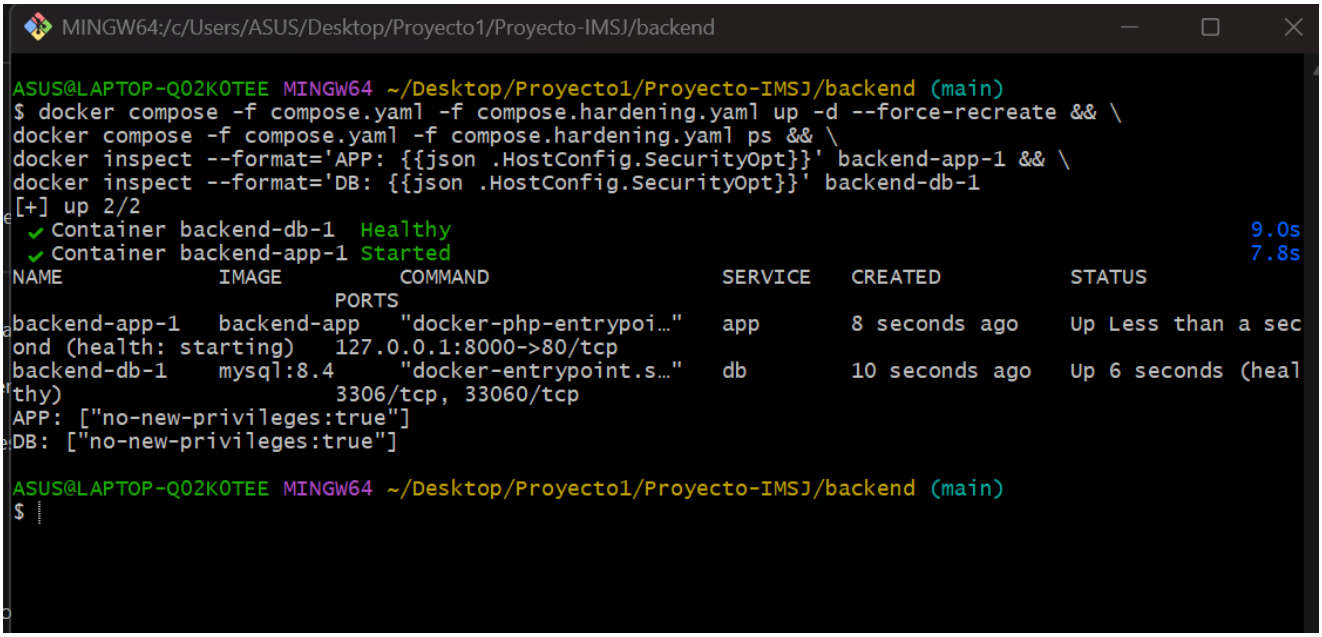


Figura 1. Primera aplicación del control security_opt en ambos servicios.

- La inspección devuelve no-new-privileges:true para app y db.
- Ambos servicios completan el arranque; la aplicación pasa a healthy segundos después, confirmado en la verificación siguiente.
- El control impide que procesos dentro del contenedor adquieran privilegios adicionales mediante binarios setuid o mecanismos equivalentes.

Evidencia 2

Usuario no privilegiado y capacidades mínimas en Apache

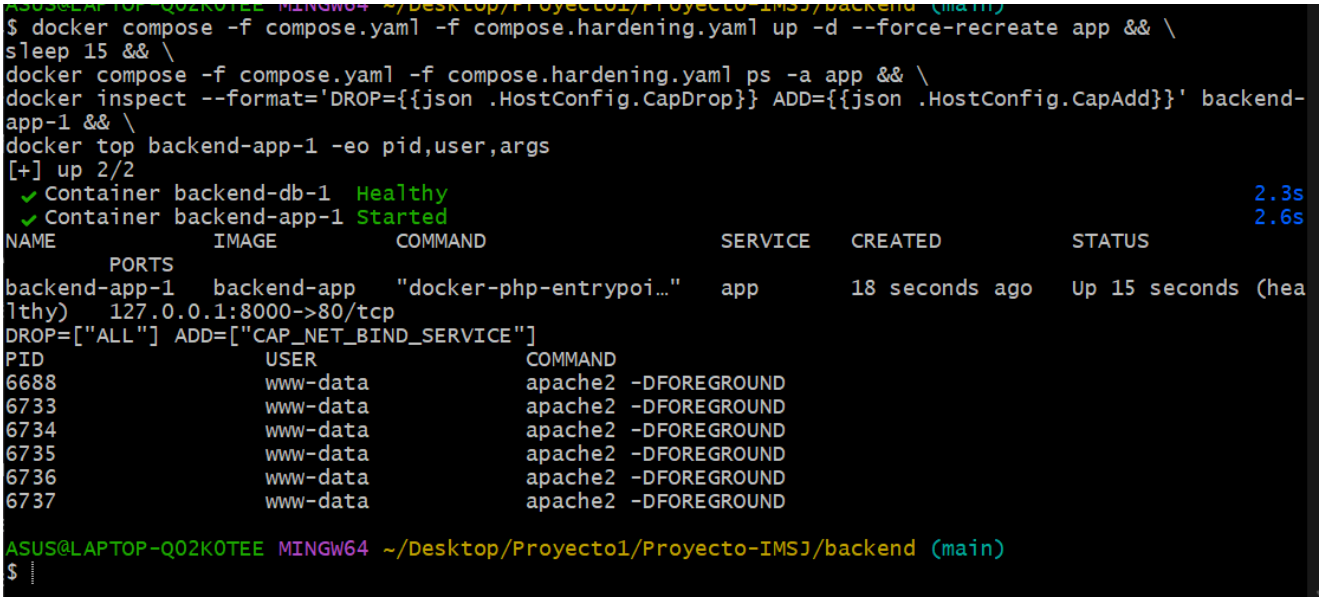


Figura 2. Estado de app después de reducir capacidades y ejecutar Apache íntegramente como www-data.

- El servicio app permanece healthy con todas las capacidades descartadas.
- Se agrega únicamente CAP_NET_BIND_SERVICE para conservar el puerto interno 80.
- Todos los procesos Apache observados se ejecutan como www-data; no queda un proceso maestro root.

Evidencia 3

Raíz de solo lectura y capacidades eliminadas en MySQL



Figura 3. Configuración efectiva del contenedor de base de datos.

- app y db aparecen healthy durante la misma verificación.
- MySQL informa READ_ONLY=true, DROP=[ALL] y ADD=null.
- El proceso mysqld utiliza UID 999, correspondiente al usuario mysql de la imagen.
- La base conserva escritura únicamente en su volumen de datos y en tmpfs temporales.

Evidencia 4

Revalidación funcional y de seguridad

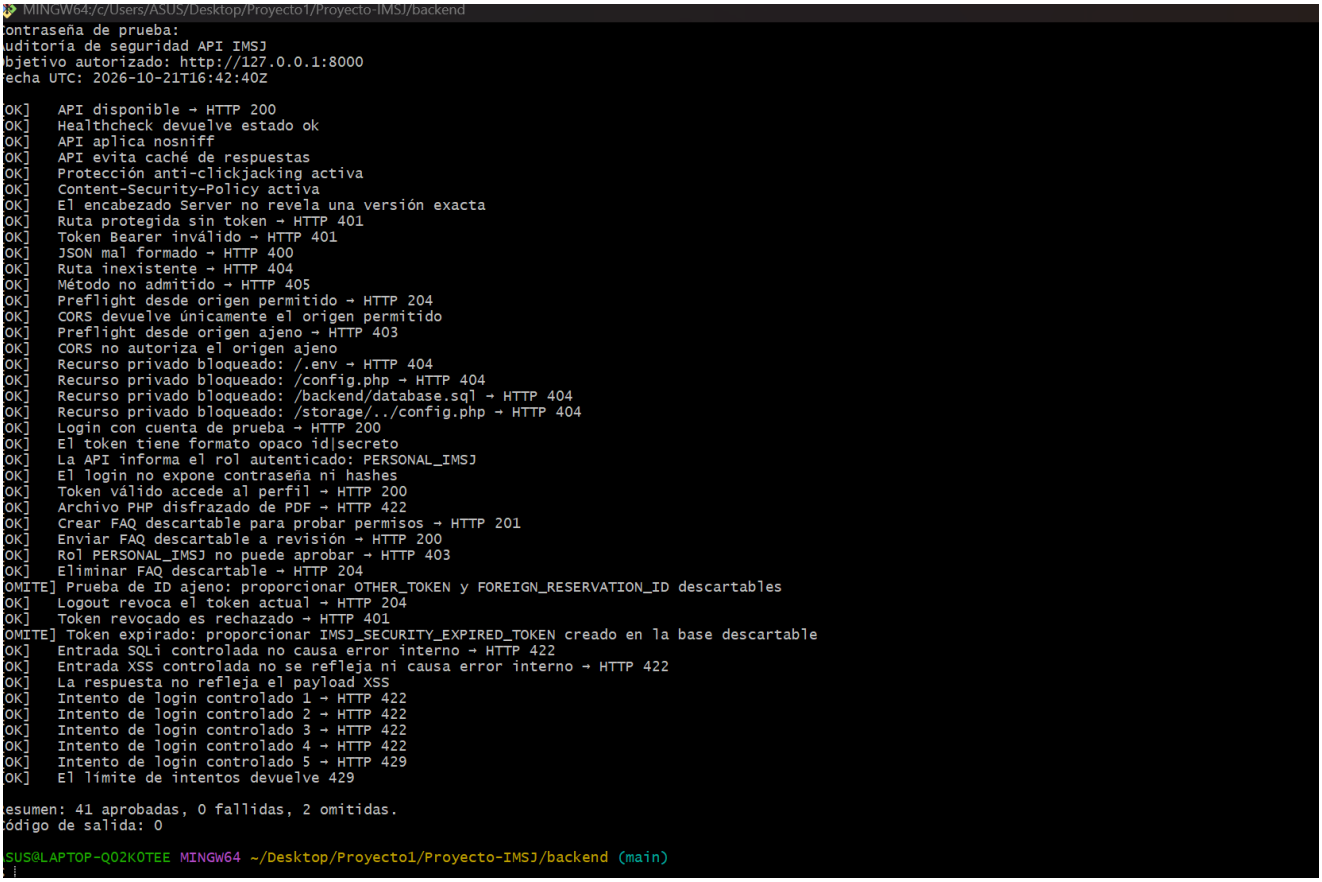


Figura 4. Auditoría Bash ejecutada nuevamente después del hardening.

- Resultado: 41 aprobadas, 0 fallidas y 2 omitidas; código de salida 0.
- La prueba incluye healthcheck, cabeceras, CORS, autenticación, rol PERSONAL_IMSJ, carga maliciosa, operaciones descartables, SQLi/XSS controladas y rate limiting.
- Las dos omisiones son token expirado e ID ajeno, ya acreditadas en la ejecución estricta anterior de 43 aprobadas, 0 fallidas y 0 omitidas.

Evidencia 5

Persistencia del hardening en el arranque habitual

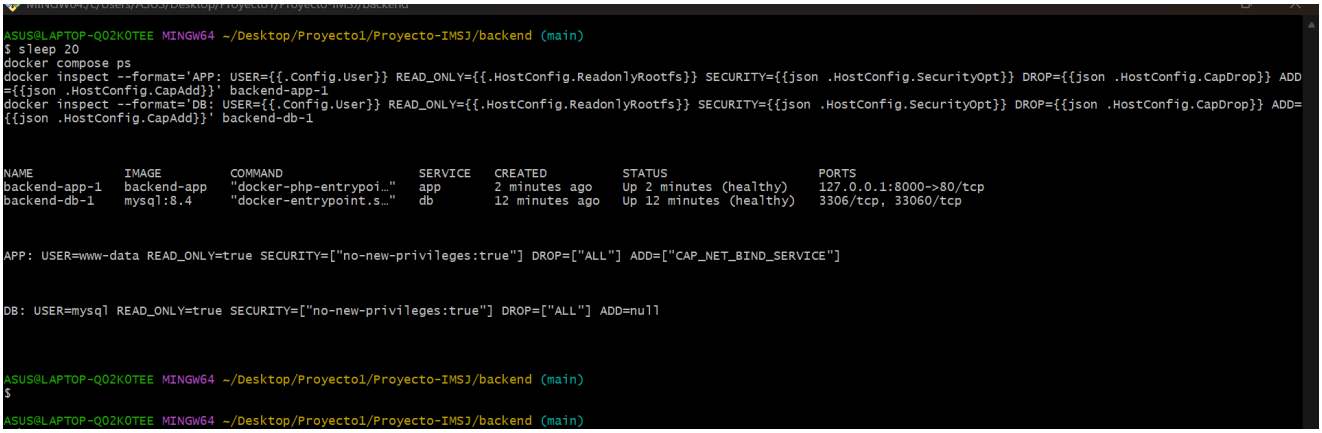


Figura 5. Inspección final después de iniciar el proyecto mediante su mecanismo habitual.

- El compose.yaml utilizado por iniciar.bat levanta app y db en estado healthy.
- app: usuario www-data, raíz de solo lectura, no-new-privileges, DROP ALL y una única capacidad agregada.
- db: usuario mysql, raíz de solo lectura, no-new-privileges, DROP ALL y ninguna capacidad agregada.
- La configuración de prueba dejó de depender de un archivo override separado.

5. Requisito HTTPS para producción

La entrega local escucha exclusivamente en 127.0.0.1 y utiliza HTTP para simplificar la demostración. Ese esquema no es una autorización para publicar el servicio sin cifrado. En un despliegue real, el tráfico externo debe terminar en un proxy inverso o balanceador con TLS 1.2 o superior, certificado válido y renovación automática.

Requisito	Decisión de despliegue
Exposición	Publicar solo 443/TCP en el proxy; mantener app y MySQL en red privada.
Redirección	Redirigir HTTP a HTTPS y evitar contenido mixto.
Certificado	Usar una autoridad confiable y automatizar renovación y alertas de vencimiento.
Cabeceras	Activar HSTS únicamente después de comprobar HTTPS en todo el dominio.
Origen	Ajustar APP_URL y FRONTEND_ORIGIN al dominio https:// definitivo.
Validación	Repetir healthchecks, Bash, ZAP y revisión de certificado sobre el despliegue final.

6. Riesgos residuales y limitaciones

• El informe valida el entorno local y no sustituye una revisión del proveedor de alojamiento, firewall, DNS, certificados ni copias de seguridad de producción.

• CAP_NET_BIND_SERVICE permanece en app para conservar el puerto interno 80. Es una concesión mínima y documentada; puede eliminarse si una imagen futura escucha en un puerto no privilegiado.

• Los volúmenes persistentes continúan siendo escribibles por diseño. Su protección depende además de permisos del host, respaldo, cifrado y control de acceso operacional.

• No se afirma ausencia total de vulnerabilidades; se informa únicamente el alcance y las pruebas descritas.

• La asociación al commit o tag definitivo permanece pendiente hasta el cierre de la entrega.

7. Integridad de la evidencia

Elemento	SHA-256
backend/compose.yaml	096769E1AB6F064620C0F2EF8ED9194AB2F8C94A0EDE5B692CA298385CA6246F
output/security-api-hardening.txt	2A7C9084745A0F6C75DD4F041550FC859BDDF1BB2314D3B7147B3E3FC34DA0CE

DICTAMEN	APROBADO PARA LA ENTREGA LOCAL
Fundamento	Configuración aplicada por defecto, servicios saludables y regresión sin fallos dentro del alcance.